

← **DSG-Prüfung Schweiz**  
Datenschutzgesetz (nDSG) – Compliance-Prüfung für BANDspirit



**Erfüllungsgrad: 81%**

58 von 72 Massnahmen umgesetzt



**20**

Prüfpunkte

**10**

Erfüllt

**10**

Teilweise

**0**

Offen

**72**

Massnahmen

🔍 Suche nach ID, Titel, Artikel oder Massnahme...

Alle Kategorien



Alle Status



DSG-001

Art. 6 DSG

**Rechtmässigkeit und Treu und Glauben**

Personendaten müssen rechtmässig und nach Treu und Glauben bearbeitet werden.

Risiko: Hoch

🟢 Erfüllt

📖 Grundsätze

① Massnahmen (4/4 umgesetzt):

- 🟢 Bearbeitung basiert auf gesetzlicher Grundlage (Organisationsverwaltung, Betriebsführung)
- 🟢 Personendaten (Benutzer) werden ausschliesslich für den definierten Zweck (Organisations- & Benutzerverwaltung) bearbeitet
- 🟢 Transparente Information der Benutzer über Datenbearbeitung

- ✓ Keine Bearbeitung auf Vorrat — nur für konkrete, aktive Organisationsprozesse

DSG-002

Art. 6 Abs. 2 DSG

### Zweckbindung

Personendaten dürfen nur zu dem Zweck bearbeitet werden, der bei der Beschaffung angegeben wurde.

Risiko: Hoch

✓ Erfüllt

#### Grundsätze

① Massnahmen (4/4 umgesetzt):

- ✓ Datenfelder sind auf den Zweck Organisationsverwaltung und Benutzeradministration beschränkt
- ✓ Keine Marketing- oder Profiling-Nutzung der Benutzerdaten
- ✓ Kein Datenaustausch mit Dritten ausserhalb des definierten Zwecks
- ✓ RBAC stellt sicher, dass nur berechtigte Rollen auf Daten zugreifen

DSG-003

Art. 6 Abs. 4 DSG

### Datenminimierung und Verhältnismässigkeit

Es dürfen nur Personendaten bearbeitet werden, die für den Zweck tatsächlich erforderlich sind.

Risiko: Mittel

✓ Erfüllt

#### Grundsätze

① Massnahmen (3/3 umgesetzt):

- ✓ Datenmodell enthält nur fachlich notwendige Felder (Benutzer, Organisation, Stammdaten)
- ✓ Optionale Felder sind nicht Pflicht
- ✓ Keine Erhebung von nicht zweckdienlichen Daten (z.B. Religion, Ethnie)

DSG-004

Art. 6 Abs. 5 DSG

### Datenrichtigkeit

Wer Personendaten bearbeitet, muss sich über deren Richtigkeit vergewissern.

Risiko: Mittel

✓ Erfüllt

#### Grundsätze

① Massnahmen (4/4 umgesetzt):

- ✓ Server-seitige Modell-Validierung (Data Annotations / ModelState) prüft Eingaben auf Korrektheit und Vollständigkeit
- ✓ Pflichtfelder sichern Mindestqualität der Daten

- ✓ Bearbeitungsfunktion ermöglicht jederzeitige Korrektur durch berechtigte Benutzer
- ✓ Audit-Trail (Application-Log) dokumentiert alle Änderungen mit Zeitstempel

DSG-005

Art. 19 DSG

### Informationspflicht bei Beschaffung

Bei der Beschaffung von Personendaten muss die betroffene Person angemessen informiert werden.

Risiko: Hoch

⚠ Teilweise

👤 Betroffenenrechte

① Massnahmen (2/3 umgesetzt):

- ✓ Benutzerregistrierung informiert über Zweck, Umfang und Empfänger der Datenerhebung
- ✓ Identität des Verantwortlichen (BANDspirit) ist klar erkennbar

⚠ Empfehlung: Schriftliche Datenschutzerklärung für Benutzer erstellen

→ Organisatorische Massnahme — Vorlage empfohlen

DSG-006

Art. 25 DSG

### Auskunftsrecht

Jede Person kann vom Verantwortlichen Auskunft darüber verlangen, ob und welche Personendaten über sie bearbeitet werden.

Risiko: Hoch

⚠ Teilweise

👤 Betroffenenrechte

① Massnahmen (2/3 umgesetzt):

- ✓ Benutzerverwaltung zeigt alle gespeicherten Benutzerdaten vollständig an
- ✓ Organisationsstrukturen (Organisations-Module) bieten vollständige Übersicht aller Zuordnungen

⚠ Empfehlung: Organisatorischen Prozess für formale Auskunftsbegehren definieren (Frist: 30 Tage)

→ Organisatorische Massnahme — SOP empfohlen

DSG-007

Art. 32 DSG

### Recht auf Berichtigung und Löschung

Betroffene können die Berichtigung unrichtiger Daten und unter bestimmten Voraussetzungen die Löschung verlangen.

Risiko: Hoch

⚠ Teilweise

👤 Betroffenenrechte

① Massnahmen (3/4 umgesetzt):

- ✓ Bearbeitungsfunktion in Benutzer- und Organisationsmodulen ermöglicht Datenkorrektur
- ✓ Benutzer können deaktiviert werden (logische Löschung)
- ✓ Benutzer können deaktiviert werden (Soft-Delete bei Abhängigkeiten)
- ⚠ **Empfehlung: Prozess für vollständige Datenlöschung (Hard-Delete) bei Bedarf definieren**  
→ Organisatorische Massnahme — für Fälle ohne Aufbewahrungspflicht

DSG-008

Art. 8 DSG

## Datensicherheit — Vertraulichkeit

Angemessene technische und organisatorische Massnahmen zur Gewährleistung der Vertraulichkeit.

Risiko: Hoch

✓ Erfüllt

🔒 **Datensicherheit (TOM)**

① Massnahmen (6/6 umgesetzt):

- ✓ Authentifizierung mit BCrypt.Net (WorkFactor 11) — kein Klartext-Passwort in DB
- ✓ Authentifizierung via JWT Bearer-Token (ASP.NET Core, 8h Gültigkeit); Frontend-Session via NextAuth.js mit sicheren Cookies (httpOnly, secure, sameSite)
- ✓ 4-stufiges RBAC-Modell mit ca. 30 granularen Berechtigungen
- ✓ Server-seitige Autorisierung in jeder API-Route (requirePermission)
- ✓ Middleware-basierter Routenschutz — kein unautorisierter Seitenzugriff
- ✓ Verschlüsselte Datenbankverbindung (SSL/TLS)

DSG-009

Art. 8 DSG

## Datensicherheit — Integrität

Schutz der Daten vor unbefugter oder unbeabsichtigter Veränderung.

Risiko: Hoch

✓ Erfüllt

🔒 **Datensicherheit (TOM)**

① Massnahmen (4/4 umgesetzt):

- ✓ Server-seitige Input-Validierung (Model Binding / ModelState) in allen API-Endpunkten
- ✓ Entity Framework Core — parametrisierte Queries (SQL-Injection-Schutz)
- ✓ XSS-Prävention: React JSX escaped alle Ausgaben, kein dangerouslySetInnerHTML
- ✓ Audit-Trail protokolliert alle Änderungen mit Benutzer und Zeitstempel

DSG-010

Art. 8 DSG

## Datensicherheit — Verfügbarkeit

Personendaten müssen verfügbar sein, wenn sie für den definierten Zweck benötigt werden.

Risiko: Mittel

⚠ Teilweise

#### 🔒 Datensicherheit (TOM)

① Massnahmen (2/3 umgesetzt):

- ✓ Hosting via Docker Compose auf Ubuntu-Server (nginx, API, Frontend, PostgreSQL, Redis, MinIO) mit Logging/Monitoring
- ✓ Datenbank mit Connection-Pooling und Timeout-Konfiguration
- ⚠ Empfehlung: Regelmässige Backups und Disaster-Recovery-Plan dokumentieren  
→ Organisatorische Massnahme — Backup-Strategie formalisieren

DSG-011

Art. 8 DSG / Art. 4 DSV

### Datensicherheit — Nachvollziehbarkeit

Datenbearbeitungen müssen nachvollziehbar und überprüfbar sein.

Risiko: Hoch

✓ Erfüllt

#### 🔒 Datensicherheit (TOM)

① Massnahmen (4/4 umgesetzt):

- ✓ Application-Log (Audit-Trail) protokolliert Login, Organisations- und Benutzeränderungen
- ✓ Unveränderlicher Log — nur Lesen, kein Löschen über die Benutzeroberfläche
- ✓ Filterbar nach Modul, Benutzer, Zeitraum und Freitext
- ✓ Jeder Eintrag enthält: Modul, Aktion, Entity, Benutzer, IP, Zeitstempel

DSG-012

Art. 7 DSG

### Datenschutz durch Technik (Privacy by Design)

Der Verantwortliche muss die Datenbearbeitung technisch so ausgestalten, dass die Datenschutzvorschriften eingehalten werden.

Risiko: Mittel

✓ Erfüllt

#### ⚙ Privacy by Design/Default

① Massnahmen (4/4 umgesetzt):

- ✓ RBAC ab Entwurf implementiert — Berechtigungen in jedem Modul erzwungen
- ✓ Passwortrichtlinie mit Komplexitätsanforderungen ab Ersterstellung
- ✓ Alle Secrets in Umgebungsvariablen — keine Credentials im Quellcode
- ✓ Generische Fehlermeldungen — keine internen Details an Client

DSG-013

Art. 7 Abs. 3 DSG

## Datenschutz durch Voreinstellungen (Privacy by Default)

Voreinstellungen müssen so konfiguriert sein, dass nur die für den Zweck erforderlichen Daten bearbeitet werden.

Risiko: Mittel

✔ Erfüllt

⚙️ Privacy by Design/Default

① Massnahmen (3/3 umgesetzt):

- ✔ Standardmässig minimale Berechtigungen — neue Benutzer erhalten Rolle mit geringstem Zugriff
- ✔ Optionale Felder sind per Default leer — keine unnötige Datenerhebung
- ✔ Benutzer sind per Default «aktiv» — keine versteckte Datenbearbeitung

DSG-014

Art. 12 DSG

## Verzeichnis der Bearbeitungstätigkeiten

Der Verantwortliche führt ein Verzeichnis der Bearbeitungstätigkeiten.

Risiko: Mittel

⚠️ Teilweise

📄 Dokumentation

① Massnahmen (3/4 umgesetzt):

- ✔ ERD / Datenmodell-Dokumentation dokumentiert alle Entitäten, Felder und Beziehungen
- ✔ Technische Dokumentation beschreibt Architektur und Datenflüsse
- ✔ Fachliche Dokumentation definiert Geschäftsprozesse und Zweckbestimmung
- ⚠️ Empfehlung: Formales Bearbeitungsverzeichnis gemäss Art. 12 DSG erstellen (Verantwortlicher, Zweck, Kategorien, Empfänger, Aufbewahrung, TOM)  
→ Organisatorische Massnahme — Vorlage gemäss EDÖB empfohlen

DSG-015

Art. 24 DSG

## Meldung von Datensicherheitsverletzungen

Der Verantwortliche meldet dem EDÖB so rasch als möglich Verletzungen der Datensicherheit, die zu einem hohen Risiko führen.

Risiko: Hoch

⚠️ Teilweise

🔔 Meldepflichten

① Massnahmen (2/4 umgesetzt):

- ✔ Application-Log ermöglicht Erkennung ungewöhnlicher Aktivitäten (fehlgeschlagene Logins)
- ✔ Rate-Limiting auf sensiblen Endpunkten (Passwort-Reset, Login)
- ⚠️ Empfehlung: Incident-Response-Plan mit Meldeprozess an EDÖB definieren

→ Organisatorische Massnahme — Eskalationsverfahren formalisieren

⚠️ **Empfehlung: Verantwortliche Person für Datensicherheitsverletzungen benennen**

→ Organisatorische Massnahme

DSG-016

Art. 22 DSG

### Datenschutz-Folgenabschätzung (DSFA)

Bei voraussichtlich hohem Risiko für Persönlichkeit oder Grundrechte ist eine DSFA durchzuführen.

Risiko: Hoch

⚠️ Teilweise

⚠️ Risikomanagement

① Massnahmen (1/3 umgesetzt):

⚠️ **System verarbeitet Personendaten im Organisationskontext — DSFA-Prüfung empfohlen**

→ Formale DSFA empfohlen — Risikobewertung vorhanden, aber nicht formalisiert

✓ Technische Schutzmassnahmen (Verschlüsselung, RBAC, Audit-Trail) mindern das Risiko erheblich

⚠️ **Empfehlung: DSFA-Dokument gemäss EDÖB-Vorlage erstellen und regelmässig überprüfen**

→ Organisatorische Massnahme

DSG-017

Art. 5 lit. c DSG

### Besonders schützenswerte Personendaten

Erhöhter Schutz für Gesundheitsdaten, Massnahmen der sozialen Hilfe und religiöse/politische Ansichten.

Risiko: Hoch

✓ Erfüllt

👁️ Besondere Datenkategorien

① Massnahmen (4/4 umgesetzt):

✓ Benutzerdaten und Rollenzuweisungen nur für berechtigte Rollen sichtbar (RBAC)

✓ Organisationsdaten über RBAC-gesicherte Endpunkte geschützt

✓ Keine Erhebung von genetischen oder biometrischen Daten

✓ Verschlüsselte Speicherung und Übertragung aller sensiblen Daten

DSG-018

Art. 9 DSG

### Bearbeitung durch Auftragsbearbeiter

Die Bearbeitung durch Dritte muss vertraglich abgesichert sein.

Risiko: Mittel

⚠️ Teilweise

📁 Auftragsbearbeitung

① Massnahmen (2/3 umgesetzt):

- ✓ Hosting-Umgebung (selbst betriebener Ubuntu-Server / gewählter Infrastruktur-Provider) als Auftragsbearbeiter identifiziert
- ✓ Datenbank-Hosting mit verschlüsselter Verbindung und Zugangskontrolle
- ⚠ **Empfehlung: Auftragsbearbeitungsvertrag (AVV/DPA) mit Hosting-Provider formalisieren**  
→ Organisatorische Massnahme — Vertragsprüfung empfohlen

DSG-019

Art. 16 DSG

### Bekanntgabe ins Ausland

Personendaten dürfen nur ins Ausland bekanntgegeben werden, wenn ein angemessenes Schutzniveau gewährleistet ist.

Risiko: Mittel

⚠ Teilweise

🌐 Datenübermittlung

🕒 Massnahmen (0/2 umgesetzt):

- ⚠ **Prüfung: Serverstandort und Datenverarbeitungsort des Hosting-Providers evaluieren**  
→ Empfehlung: Bestätigung des Serverstandorts einholen
- ⚠ **Empfehlung: Falls Datenübermittlung in Drittland — Standardvertragsklauseln (SCC) oder Angemessenheitsbeschluss prüfen**  
→ Organisatorische Massnahme — je nach Serverstandort

DSG-020

Art. 6 Abs. 4 DSG

### Aufbewahrungsdauer und Löschkonzept

Personendaten sind zu vernichten oder zu anonymisieren, sobald sie für den Bearbeitungszweck nicht mehr erforderlich sind.

Risiko: Mittel

⚠ Teilweise

📅 Datenlebenszyklus

🕒 Massnahmen (1/3 umgesetzt):

- ✓ Benutzer können deaktiviert werden — logische Archivierung
- ⚠ **Empfehlung: Aufbewahrungsfristen je Datenkategorie definieren**  
→ Organisatorische Massnahme — unter Berücksichtigung gesetzlicher Aufbewahrungspflichten
- ⚠ **Empfehlung: Automatisiertes Lösch-/Anonymisierungskonzept für abgelaufene Daten**  
→ Technisch-organisatorische Massnahme — Löschroutine definieren

## 📌 Umgesetzte und offene Datenschutz-Massnahmen

- ✓ **Umgesetzt (Korrektur 35 — DSGVO-M1):**

- **Log-Minimierung:** AppLog.Details-Feld strukturiert als JSON (statt Freitext), keine sensiblen Daten in Logs, minimale Retention (Empfehlung 90 Tage)
- Audit-Trail protokolliert nur fachliche Änderungen und Fehler (keine erfolgreichen Read-Requests)

⚠️ ⚠️ **Offene Maßnahmen (DSGVO-M2 bis M6):**

- **DSGVO-M2:** Betroffenenrechte — API-Endpunkte für Auskunft/Berichtigung/Löschung (Art. 25, 32 DSG)
- **DSGVO-M3:** Automatisiertes Löschkonzept — Anonymisierung abgelaufener Daten nach Aufbewahrungsfristen
- **DSGVO-M4:** Pseudonymisierung — Trennung von Identität und fachlichen Daten wo möglich
- **DSGVO-M5:** Auftragsbearbeitungsvertrag (AVV/DPA) mit Hosting-Provider formalisieren
- **DSGVO-M6:** TOM-Dokumentation — Verschlüsselung at-rest (Database Encryption), formalisierte DSFA

---

Stand: 23.08.2026 — Technische Grundmaßnahmen (Verschlüsselung TLS, RBAC, Audit-Trail, Log-Minimierung) umgesetzt. Organisatorische und erweiterte technische Maßnahmen (M2-M6) stehen aus.

**Rechtsgrundlage:**

Bundesgesetz über den Datenschutz (DSG) vom 25. September 2020, in Kraft seit 1. September 2023 (nDSG/revDSG)

Verordnung über den Datenschutz (DSV) vom 31. August 2022

Zuständige Behörde: Eidgenössischer Datenschutz- und Öffentlichkeitsbeauftragter (EDÖB)

BANDspirit — Version V.2.0